

---

# System Architecture

HR Assistant

---

Dokumentasi teknis arsitektur, alur runtime, data, keamanan,  
dan deployment aktual HR Assistant.

# Contents

---

|                                                |           |
|------------------------------------------------|-----------|
| <b>1 Konteks Sistem</b>                        | <b>3</b>  |
| 1.1 Tujuan dan Ruang Lingkup . . . . .         | 3         |
| 1.2 Fitur Inti . . . . .                       | 3         |
| 1.3 Tech Stack . . . . .                       | 3         |
| <b>2 Struktur Repository</b>                   | <b>4</b>  |
| <b>3 Ringkasan Arsitektur</b>                  | <b>5</b>  |
| 3.1 Keputusan Utama . . . . .                  | 5         |
| 3.2 Komponen Kode Inti . . . . .               | 5         |
| 3.3 API Overview . . . . .                     | 6         |
| <b>4 Diagram Arsitektur Sistem</b>             | <b>7</b>  |
| <b>5 Data dan Konfigurasi</b>                  | <b>8</b>  |
| 5.1 Model Data Inti . . . . .                  | 8         |
| 5.2 Konfigurasi Wajib . . . . .                | 8         |
| <b>6 Alur Chat End-to-End</b>                  | <b>9</b>  |
| <b>7 Alur Ingestion Dokumen</b>                | <b>10</b> |
| <b>8 Keamanan dan Otorisasi</b>                | <b>11</b> |
| <b>9 Deployment Aktual EC2</b>                 | <b>12</b> |
| 9.1 Instance dan Host . . . . .                | 12        |
| 9.2 Network dan Reverse Proxy . . . . .        | 12        |
| 9.3 Container dan Persistent Storage . . . . . | 13        |
| <b>10 Dependency dan Catatan Operasional</b>   | <b>14</b> |
| 10.1 Proses Update . . . . .                   | 14        |
| <b>11 Skalabilitas dan Keterbatasan</b>        | <b>15</b> |
| <b>12 Rekomendasi</b>                          | <b>16</b> |

## 1 Konteks Sistem

### 1.1 Tujuan dan Ruang Lingkup

HR Assistant adalah aplikasi internal berbasis RAG untuk mencari informasi dari SOP, kebijakan HR, dan panduan perusahaan melalui antarmuka percakapan. Jawaban menyertakan citation dan form download ketika tersedia. Admin mengelola dokumen, FAQ, guardrails, activity log, feedback, serta analytics.

| Area               | Kondisi aktual                                                                                                        |
|--------------------|-----------------------------------------------------------------------------------------------------------------------|
| Runtime            | Monolith FastAPI pada satu EC2; frontend utama disajikan sebagai static files.                                        |
| Data               | PostgreSQL untuk state, analytics, dan metadata cache; ChromaDB lokal untuk document index dan vector semantic cache. |
| AI                 | 9Router/Kiro untuk chat completion, Nscale untuk embedding, dan Langfuse opsional untuk tracing.                      |
| Akses              | Satu Google sign-in flow. Role admin berasal dari kecocokan email pada <code>app.admin_accounts</code> .              |
| Batas implementasi | HTTPS dan SAML tidak diimplementasikan. Tidak ada HA atau pipeline CI/CD terkelola.                                   |

### 1.2 Fitur Inti

- Chat RAG dengan conversation history, citations, dan form recommendations.
- Context resolution untuk follow-up question dan semantic cache setelah thumbs-up.
- Upload dokumen, reindex, FAQ, guardrails, feedback, activity log, dan analytics admin.
- Optional reranking dan diagram description jika dependency tersedia.

### 1.3 Tech Stack

| Layer            | Teknologi                                           |
|------------------|-----------------------------------------------------|
| Backend          | Python 3.12, FastAPI, SQLAlchemy, Alembic, ChromaDB |
| Frontend (User)  | Vanilla JS SPA, static HTML/CSS/JS                  |
| Frontend (Admin) | React 19, TypeScript, Vite, Recharts                |
| Database         | PostgreSQL 16                                       |
| Vector Store     | ChromaDB (persistent local)                         |
| AI/LLM           | Claude via 9Router/Kiro (OpenAI-compatible API)     |
| Embeddings       | Nscale (OpenAI-compatible endpoint)                 |
| Observability    | Langfuse (optional tracing)                         |
| Infrastructure   | AWS EC2 (t3.medium), Docker Compose, Nginx          |

## 2 Struktur Repository

```

<project-root>/
|-- backend/
|   |-- api/
|   |   |-- main.py           # FastAPI routes, auth, storage, models
|   |   |-- core.py          # Application entry point
|   |   |-- routes_public.py  # App factory, middleware, static mounts
|   |   |-- routes_admin.py   # Query, conversations, download
|   |   |-- routes_auth.py    # Documents, reindex, FAQ, logs
|   |   |-- routes_analytics.py # Google login flow
|   |   |-- routes_analytics.py # Analytics dashboard routes
|   |   |-- auth.py           # HMAC session + Google verification
|   |   '-- storage.py        # Document and form management
|   |-- researcher_crew/
|   |   '-- src/researcher_crew/
|   |       |-- main.py       # RAG orchestrator
|   |       |-- context_graph.py
|   |       |-- context_schema.py
|   |       '-- tools/custom_tool.py
|   |-- preprocessing/
|   |   |-- ingest.py         # Ingestion entry point
|   |   |-- loader.py         # PDF/DOCX/TXT loader
|   |   |-- chunker.py        # AI chunking + fallback
|   |   |-- diagram_description.py
|   |   |-- embedding.py      # Nscale embeddings
|   |   '-- vectorstore.py    # ChromaDB index
|   |-- analytics/           # Topic and aggregate processing
|   |-- db/
|   |   |-- models.py         # SQLAlchemy ORM
|   |   |-- engine.py         # Synchronous engine/session
|   |   |-- repository.py     # Database operations
|   |   '-- alembic/          # Migration scripts
|   |-- data/                # Source documents and forms
|   |-- settings.py          # Environment helpers
|   |-- semantic_cache.py
|   '-- observability.py
|-- frontend/
|   |-- web/                  # Main static SPA
|   '-- dashboard/           # React/Vite analytics source
|-- deploy/
|   |-- nginx/hr-agent.conf   # Reverse proxy config
|   '-- update-ec2.sh         # EC2 update script
|-- docs/                    # Architecture and admin guide
|-- docker-compose.yml        # Production services
|-- docker-compose.dev-db.yml # Local development PostgreSQL
|-- Dockerfile
|-- alembic.ini
|-- requirements.txt
|-- .env.example
|-- run.bat
'-- clean.bat

```

## 3 Ringkasan Arsitektur

---

### 3.1 Keputusan Utama

- **Auth:** semua account login dengan Google; admin ditentukan oleh `app.admin_accounts`.
- **Session:** token HMAC-SHA256 berlaku 12 jam; role diperiksa kembali dari PostgreSQL.
- **Data:** PostgreSQL menjadi source of truth untuk state dan metadata cache; ChromaDB menyimpan document vectors dan vector index semantic cache.
- **Retrieval:** semantic search dengan optional rerank; jawaban baru di-cache setelah thumbs-up.
- **Runtime:** single-instance deployment dipilih untuk operasional sederhana saat ini.

### 3.2 Komponen Kode Inti

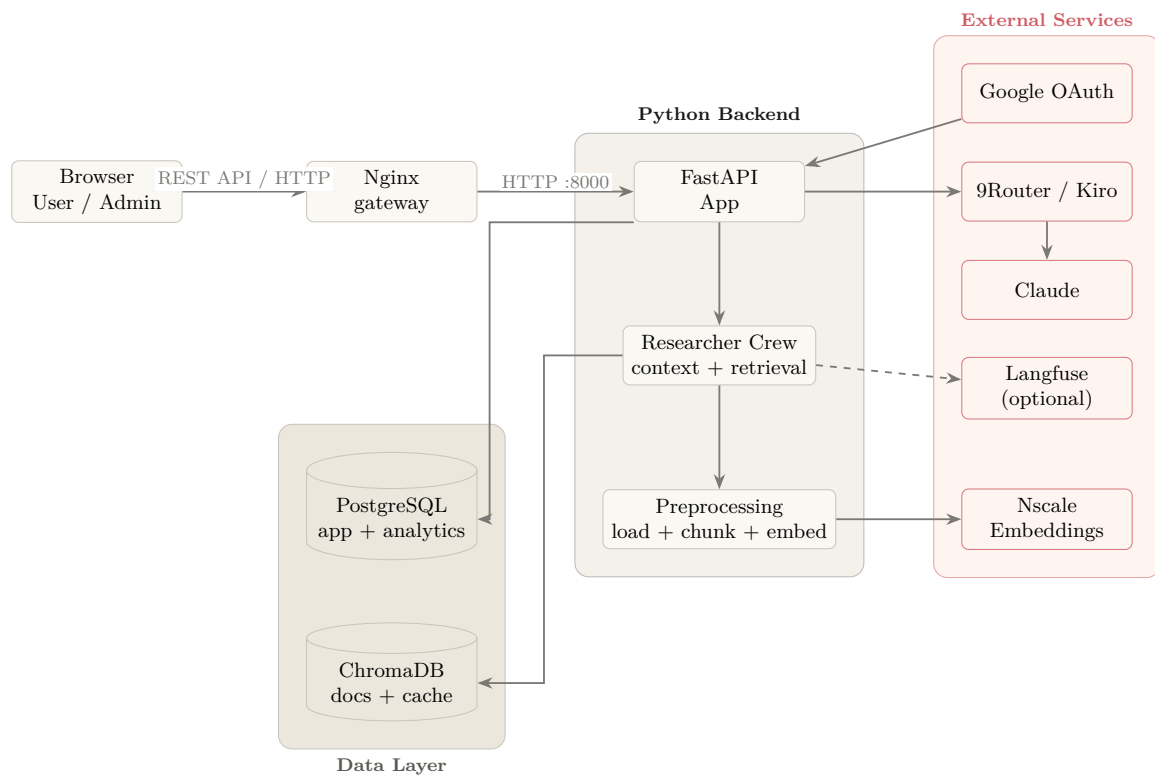
| Komponen                            | Tanggung jawab                                                           |
|-------------------------------------|--------------------------------------------------------------------------|
| backend/api/*                       | FastAPI app, auth, user/admin/analytics routes, storage, FAQ, dan forms. |
| backend/<br>researcher_crew/*       | Context graph, retrieval, prompt, dan orchestrator jawaban.              |
| backend/preprocessing/*             | Loader, visual description, chunking, embedding, dan vector store.       |
| backend/db/*                        | SQLAlchemy synchronous ORM, repository, engine, dan Alembic.             |
| backend/analytics/*                 | Topic classification, canonical interactions, dan daily aggregates.      |
| frontend/web,<br>frontend/dashboard | SPA utama vanilla JS dan dashboard admin React/Vite.                     |

### 3.3 API Overview

Semua endpoint berada di bawah FastAPI monolith pada port 8000. Autentikasi menggunakan session token di header.

| Method | Endpoint                        | Deskripsi                                  |
|--------|---------------------------------|--------------------------------------------|
| POST   | /api/auth/google                | Login via Google ID token, return session. |
| POST   | /query                          | Kirim pertanyaan ke RAG pipeline.          |
| GET    | /api/conversations              | List conversation history user.            |
| GET    | /api/conversations/:id/messages | Detail messages pada conversation.         |
| POST   | /api/feedback                   | Submit feedback (thumbs up/down).          |
| GET    | /api/library                    | List dokumen dan form yang dapat diakses.  |
| POST   | /api/admin/documents            | Upload dokumen baru.                       |
| POST   | /api/admin/reindex              | Trigger reindex embedding.                 |
| GET    | /api/faq                        | List FAQ items yang dipublikasikan.        |
| GET    | /api/admin/logs                 | Activity log dan session history.          |
| GET    | /api/admin/analytics/*          | Analytics data (overview, charts, topics). |
| GET    | /health                         | Basic health check.                        |

## 4 Diagram Arsitektur Sistem



Dependency runtime utama; external services ditandai outline merah.

## 5 Data dan Konfigurasi

### 5.1 Model Data Inti

| Tabel                                            | Peran                                                     |
|--------------------------------------------------|-----------------------------------------------------------|
| app.users,<br>app.admin_accounts                 | Identitas Google dan allowlist role admin tanpa password. |
| app.conversations,<br>app.conversation_messages  | Riwayat chat dan metadata jawaban, citation, serta form.  |
| app.faq_items                                    | FAQ berbasis knowledge base beserta citation metadata.    |
| app.activity_logs,<br>app.semantic_cache_entries | Log/feedback produk dan metadata semantic cache.          |
| analytics.canonical_<br>interactions             | Interaksi ternormalisasi untuk analytics.                 |
| analytics.daily_topic_<br>aggregates             | Rollup harian topic, user, feedback, dan fallback/error.  |
| app.app_state_meta                               | Session signing, guardrails, dan metadata state.          |

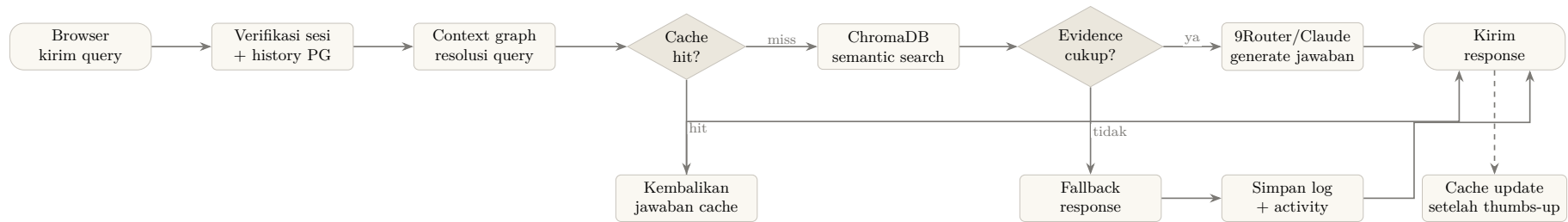
### 5.2 Konfigurasi Wajib

| Variable / group                            | Fungsi                                                     |
|---------------------------------------------|------------------------------------------------------------|
| DATABASE_URL                                | PostgreSQL connection string.                              |
| MODEL, CHAT_BASE_URL                        | Model chat dan endpoint 9Router/OpenAI-compatible.         |
| NSCALE_SERVICE_TOKEN,<br>EMBED_MODEL        | Credential dan model embedding.                            |
| GOOGLE_CLIENT_ID                            | Verifikasi Google login dan rendering sign-in.             |
| DATA_DIR, CHROMA_DIR,<br>SEMANTIC_CACHE_DIR | Source documents dan persistent vector stores.             |
| LANGFUSE_*                                  | Tracing opsional; switch default aktif dan IO mode masked. |



## 6 Alur Chat End-to-End

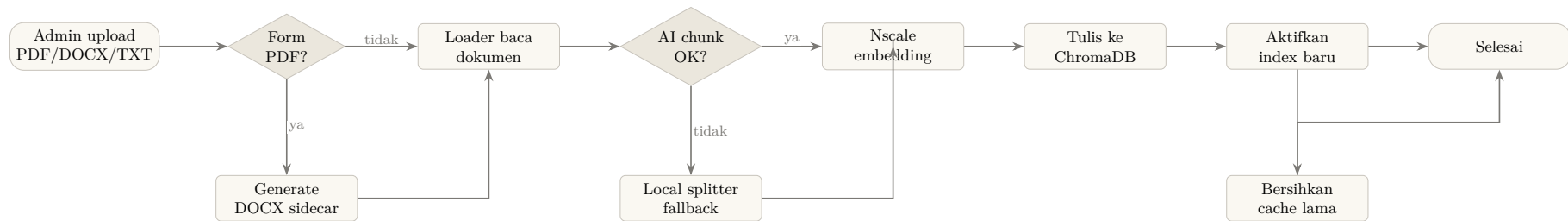
---



Alur utama (atas) dan jalur alternatif (bawah); cache hanya diperbarui setelah feedback positif.

## 7 Alur Ingestion Dokumen

---



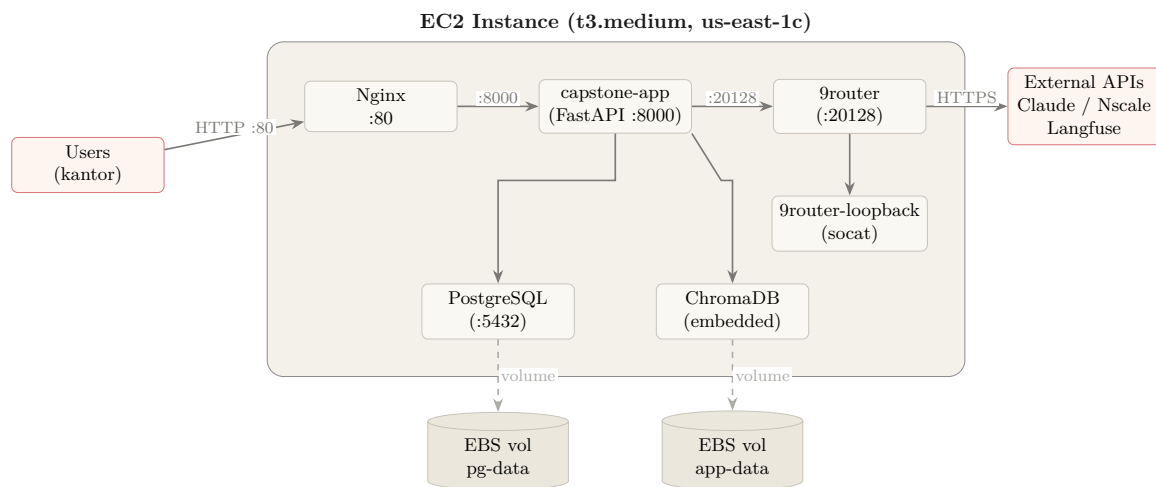
Alur ingestion utama (atas); sidecar PDF dan fallback chunking ditampilkan di baris bawah.

## 8 Keamanan dan Otorisasi

---

| Kontrol        | Implementasi aktual                                                                                                      |
|----------------|--------------------------------------------------------------------------------------------------------------------------|
| Authentication | Google ID token untuk semua user/admin; hosted domain divalidasi.                                                        |
| Admin role     | Email pada <code>app.admin_accounts</code> berarti admin; email lain berarti user.                                       |
| Session        | HMAC-SHA256, expiry 12 jam, secret acak di PostgreSQL; logout menghapus sesi lokal dan menonaktifkan Google auto-select. |
| Authorization  | FastAPI dependencies membedakan user/admin dan memeriksa row user live.                                                  |
| File handling  | Validasi extension, ukuran, path traversal, document kind, dan replacement path.                                         |
| Privacy        | Analytics memakai pseudonymous user ID; Langfuse masked mode meredaksi pola sensitif.                                    |
| Gap            | Belum ada rate limiting, server-side token revocation list, dependency scan, atau TLS termination.                       |

## 9 Deployment Aktual EC2



Snapshot deployment yang diaudit menggunakan satu EC2; Compose proyek mengelola app dan 9Router, sedangkan PostgreSQL harus tersedia melalui DATABASE\_URL.

### 9.1 Instance dan Host

| Aspek               | Nilai aktual                                                        |
|---------------------|---------------------------------------------------------------------|
| Public hostname     | ec2-98-81-149-80.<br>compute-1.amazonaws.com                        |
| Instance / lokasi   | t3.medium, Availability Zone us-east-1c                             |
| OS / kernel         | Amazon Linux 2023.12; kernel 6.18 x86_64                            |
| Compute             | 2 vCPU, RAM 3.7 GiB, tanpa swap                                     |
| Root storage        | EBS 25 GiB, XFS; 12 GiB terpakai (45%) saat audit                   |
| Runtime tools       | Docker 25.0.14, Compose 5.3.1, Nginx 1.30.3                         |
| Repository checkout | Branch <code>main</code> , revision <code>f36db57</code> saat audit |

### 9.2 Network dan Reverse Proxy

Nginx aktif dan menerima HTTP pada port 80, dengan `client_max_body_size` 50M, lalu meneruskan request ke `127.0.0.1:8000`. SSH mendengarkan port 22. PostgreSQL (5432), 9Router (20128), dan FastAPI (8000) hanya bind ke loopback host.

Instance memakai Security Group `sg-06ef9252c75a9d9e9`. Akses inbound HTTP/SSH dibatasi ke public egress jaringan kantor berdasarkan konfirmasi owner, sehingga aplikasi tidak ditujukan untuk akses internet umum.

### 9.3 Container dan Persistent Storage

| Service                | Image / port                                                 | Kondisi saat audit                                                                  |
|------------------------|--------------------------------------------------------------|-------------------------------------------------------------------------------------|
| app                    | Custom<br>127.0.0.1:8000                                     | app; Up 10 hari; restart <b>unless-stopped</b> ; belum memiliki Docker healthcheck. |
| 9router                | decolua/<br>9router:latest;<br>127.0.0.1:20128               | Up 10 hari; restart <b>unless-stopped</b> ; tanpa healthcheck.                      |
| 9router-loopback       | alpine/<br>socat:latest                                      | Up 10 hari; forward internal; tanpa healthcheck.                                    |
| postgres               | postgres:16-alpine;<br>127.0.0.1:5432                        | Up 10 hari dan healthy; restart <b>unless-stopped</b> .                             |
| Docker volume          | Penggunaan saat audit                                        |                                                                                     |
| App storage volume     | 49 MiB; menyimpan source documents dan ChromaDB.             |                                                                                     |
| PostgreSQL data volume | 48 MiB; data PostgreSQL self-hosted pada instance yang sama. |                                                                                     |

PostgreSQL production aktual berjalan sebagai container lokal pada EC2, bukan RDS. App, database, documents, dan vector index tetap memiliki satu failure domain.

## 10 Dependency dan Catatan Operasional

| Area           | Catatan penting                                                                                                                           |
|----------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| Nscale         | Embedding API masih memakai akun pribadi. Kehilangan akses menghentikan ingestion dan semantic retrieval yang membutuhkan embedding baru. |
| 9Router / Kiro | Bergantung pada Kiro/AWS Builder ID di host; image memakai tag <b>latest</b> .                                                            |
| Google OAuth   | Wajib untuk membuat sesi user maupun admin baru.                                                                                          |
| Langfuse       | Opsional dan fail-open; switch default aktif, tetapi trace hanya dikirim jika key dan base URL tersedia.                                  |
| Security Group | <b>sg-06ef9252c75a9d9e9</b> ; akses office-only dikonfirmasi owner.                                                                       |
| HTTPS          | Belum aktif; Nginx hanya listen port 80 dan tidak ditemukan TLS certificate/termination pada host.                                        |
| Health         | Hanya PostgreSQL memiliki Docker healthcheck. Endpoint app <b>/health</b> belum memeriksa dependency.                                     |

### 10.1 Proses Update

Script `deploy/update-ec2.sh` membackup konfigurasi, memvalidasi Compose, menjalankan rebuild/recreate container, menerapkan Alembic migration, memeriksa 9Router/model, lalu melakukan polling **/health**. Semua container memakai restart policy **unless-stopped**.

## 11 Skalabilitas dan Keterbatasan

| Aspek              | Kondisi saat ini                                                                                                                            |
|--------------------|---------------------------------------------------------------------------------------------------------------------------------------------|
| Concurrent users   | Single-process FastAPI dengan synchronous ORM; ditujukan untuk beban internal kecil dan belum memiliki hasil load test formal.              |
| Horizontal scaling | Belum didukung langsung — ChromaDB dan file dokumen lokal memerlukan shared storage atau vector service sebelum app dibuat multi-instance.  |
| Database           | Snapshot produksi memakai PostgreSQL container lokal; SQLAlchemy pool dikonfigurasi, tetapi belum ada read replica atau failover terkelola. |
| Vector store       | ChromaDB bersifat embedded; untuk skala lebih besar perlu migrasi ke managed vector DB (e.g., Pinecone, pgvector).                          |
| Storage            | EBS 25 GiB shared antara OS, app, dan data; perlu monitoring kapasitas.                                                                     |
| Bottleneck utama   | LLM API latency dan embedding API menjadi limiting factor untuk response time, bukan compute lokal.                                         |
| Path to scale      | Jika perlu scaling: pisahkan database ke RDS, gunakan managed vector store, dan tambahkan load balancer di depan multiple app instances.    |

### Catatan kapasitas

Dengan t3.medium (2 vCPU, 3.7 GiB RAM) dan single-process deployment, sistem mampu melayani operasi internal sehari-hari. Peningkatan beban signifikan memerlukan revisi arsitektur pada layer database dan vector store terlebih dahulu.

## 12 Rekomendasi

---

| Rekomendasi                      | Alasan                                                                                                                                                                     |
|----------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Migrasikan Nscale                | Embedding API masih menggunakan akun pribadi — perlu dipindahkan ke akun organisasi agar tidak bergantung pada satu individu.                                              |
| Aktifkan HTTPS                   | Saat ini traffic berjalan plain HTTP. Perlu TLS termination agar komunikasi terenkripsi.                                                                                   |
| Perbaiki deployment              | Deployment saat ini hanya menggunakan satu EC2 tanpa load balancer, auto-scaling, atau redundansi. Image container masih memakai tag <code>latest</code> tanpa versioning. |
| Kelola infrastructure as code    | Security group dan konfigurasi network belum didefinisikan sebagai code, sehingga sulit diaudit dan direproduksi.                                                          |
| Tambah health check dan alerting | Hanya PostgreSQL yang memiliki healthcheck. Perlu monitoring dependency-aware dan alerting untuk error rate, disk, dan availability.                                       |